

Access Control Policy

Persistence

Owner: Founder (acting Security Lead) · **Contact:** support@persistence.finance

Version: 1.0 · **Effective:** 2026-06-16 · **Review cadence:** at least annually, and after any material change

1. Purpose & scope

This policy governs how access to Persistence systems and data is granted, controlled, reviewed, and revoked. It covers all systems that store or process **consumer financial data** obtained through Plaid — the web app, desktop app, API, and database — and the third-party consoles used to operate them (Railway, Vercel, GitHub, Plaid, Google Cloud). It applies to all personnel and to the end users of the product.

2. Roles & responsibilities

The **Founder, acting as Security Lead**, is the access approver and is accountable for granting, reviewing, and revoking access. Access requests, changes, and reviews are recorded by the Security Lead. Persistence currently operates as a small team; where separation of duties is not yet practical, the Security Lead applies compensating controls (logging and periodic review).

3. Guiding principles

- **Least privilege:** each account receives only the access required for its function.
- **Need-to-know:** access to sensitive data is granted only where there is a clear operational need.
- **Default-deny:** access is denied unless explicitly granted.
- **Unique identity & accountability:** every actor uses a unique, attributable account — no shared or generic logins.

4. Account provisioning & de-provisioning

- Administrative accounts on production systems are created only with Security Lead approval.
- Each administrator uses a unique account; credentials are never shared.
- Access is revoked promptly on role change or departure, and any shared secrets that were accessible are rotated.

5. Authentication & MFA

- **Multi-factor authentication (MFA) is required** on every account that can access production systems or consumer financial data (Railway, Vercel, GitHub, Plaid, Google).
- Administrators use strong, unique passwords (managed in a password manager) and prefer authenticator apps (TOTP) or passkeys for the second factor.
- End-user passwords (for email sign-in) are stored only as bcrypt hashes; Google sign-in handles no password at all.

6. Privileged / administrative access

Access to production consoles (hosting, database, source control, the Plaid and Google Cloud dashboards) is restricted to the Security Lead and explicitly authorized personnel. The production database is not publicly exposed and is reachable only via credentialed connections. Secrets (database URL, JWT signing key, Plaid/Google/Anthropic/Stripe keys, the data-encryption key) live in the hosting providers' secret stores, are never committed to source control, and are accessible only to authorized administrators.

7. End-user (consumer) access controls

- Users must authenticate (Google OAuth or email + password) before any account linking or data access.
- Sessions use short-lived access tokens (15 minutes) renewed via rotating refresh tokens; every API request is authenticated and rate-limited.
- Users can access only their own data; records are scoped to the authenticated user. Bank login credentials are never received or stored — authentication happens inside Plaid's secure flow.
- The desktop app stores session credentials in the operating-system keychain (Windows Credential Manager), not in plaintext files.

8. Endpoint & remote access

Personnel access production only from up-to-date devices that are password/biometric-protected, have full-disk encryption enabled, and run reputable anti-malware. Production secrets must not be stored in plaintext on local devices, and accounts must not be shared.

9. Access reviews

The Security Lead reviews accounts and their permissions across all production systems periodically (at least annually, and after any material change), removing access that is no longer needed and confirming MFA remains enforced.

10. Logging & monitoring

Authentication and administrative actions are recorded through the providers' audit facilities; application errors are captured via Sentry (when enabled); and anomalous bank-connection states trigger user-facing re-authentication alerts. The API is served with hardened security headers.

11. Policy review

This policy is reviewed by the Security Lead at least annually and after any material change to systems, data flows, or personnel. It complements the Persistence Information Security Policy and the public commitments at <https://persistence.finance/security.html> and <https://persistence.finance/privacy.html>.